



Nombre:

Fernanda Guadalupe Rodríguez Pérez

Profesor:

Gerardo Ramírez Villarreal

Entregable:

Práctica 1

Grupo:

IDGS17

Fecha:

19/05/2026

Tabla comparativa de las 10 vulnerabilidades

Clave	Nombre	Descripción corta	Ejemplo de ataque	Impacto potencial	Método de mitigación
A01	Broen Access Control	Ocurre cuando el sistema no valida correctamente los permisos del usuario.	Un usuario cambia el ID en la URL para ver información de otra cuenta.	Robo, modificación o eliminación de datos privados.	Validar permisos en el servidor y aplicar control de roles.
A02	Cryptgraphic Failures	Fallas al proteger datos sensibles mediante cifrado o hashing.	Contraseñas guardadas con cifrado débil o datos enviados sin HTTPS.	Exposición de contraseñas, tarjetas o información personal.	Usar HTTPS, bcrypt/Argon2 y cifrado seguro.
A03	Injection	Entrada maliciosa que se interpreta como comando o consulta.	Ingresar código SQL en un formulario de login.	Acceso no autorizado, robo o eliminación de información.	Usar consultas parametrizadas y validar entradas.
A04	Inscure Design	El sistema fue diseñado sin controles de seguridad adecuados.	Flujo de recuperación de contraseña fácil de abusar.	Fraude, acceso indebido o abuso de funciones.	Hacer modelado de amenazas y diseñar controles desde el inicio.
A05	Security Misconfiguration	Configuraciones incorrectas	Base de datos pública sin autenticación.	Exposición de datos o acceso al sistema.	Configurar permisos mínimos y revisar entornos.
A06	Vulnerable and Outated Components	Uso de librerías o software con vulnerabilidades conocidas.	Usar una versión antigua de	Ejecución remota de código o	Actualizar dependencias y revisar vulnerabilidades.

			una librería vulnerable.	robo de datos.	
A07	Identification and Authentication Failures	Fallas en login, sesiones o recuperación de cuentas.	Contraseñas débiles o tokens de sesión robados.	Suplantación de identidad.	MFA, bloqueo de intentos y manejo seguro de sesiones.
A08	Software and Data Integrity Failures	No se verifica la integridad de código, actualizaciones o datos.	Actualización manipulada con código malicioso.	Compromiso del sistema o distribución de malware.	Firmar actualizaciones y proteger CI/CD.
A09	Security Logging and Monitoring Failures	Falta de registros, alertas o monitoreo de eventos sospechosos.	Un ataque ocurre durante semanas sin ser detectado.	Mayor daño y dificultad para investigar.	Implementar logs, alertas y monitoreo continuo.
A10	Server-Side Request Forgery	El atacante hace que el servidor realice peticiones no autorizadas.	Enviar una URL interna para que el servidor la consulte.	Acceso a servicios internos o metadatos de nube.	Validar URLs, bloquear redes internas y usar listas permitidas.

Evidencia

Top 10 de seguridad de API de OWASP

Inicio 2023 2019

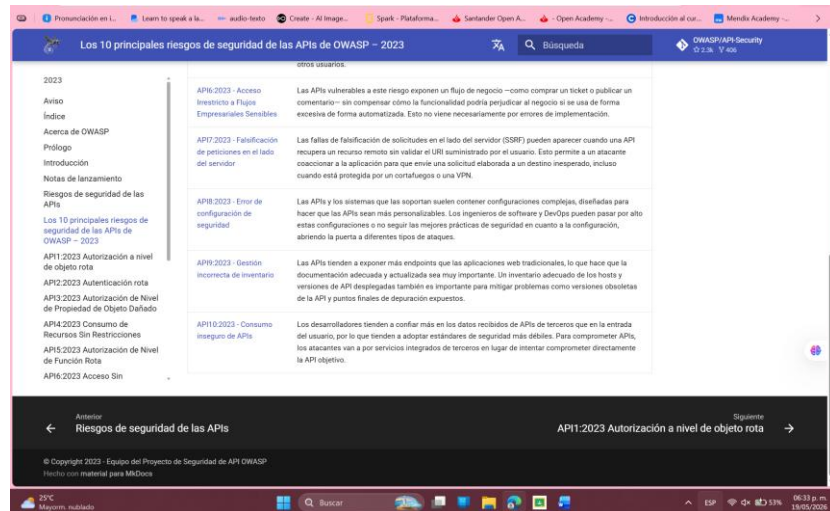
2023
Aviso
Índice
Acerca de OWASP
Prólogo
Introducción
Notas de lanzamiento
Riesgos de seguridad de las APIs
Los 10 principales riesgos de seguridad de las APIs de OWASP – 2023
API1:2023 Autorización a nivel de objeto rota
API2:2023 Autenticación rota
API3:2023 Autorización de Nivel de Propiedad de Objeto Dañado
API4:2023 Consumo de Recursos Sin Restricciones
API5:2023 Autorización de Nivel de Función Rota
API6:2023 Acceso Sin Restricciones a Puntos Empresariales Sensibles
Falsificación de peticiones en el servidor API7:2023

Los 10 principales riesgos de seguridad de las APIs de OWASP – 2023

Riesgo	Descripción
API1:2023 - Autorización a nivel de objeto rota	Las APIs tienden a exponer endpoints que gestionan identificadores de objetos, creando una amplia superficie de ataque de problemas de Control de Acceso a Nivel de Objeto. Las compromisiones de autorización a nivel de objeto deben considerarse en cada función que accede a una fuente de datos usando un ID del usuario.
API2:2023 - Autenticación rota	Los mecanismos de autenticación suelen implementarse de forma incorrecta, permitiendo a los atacantes comprometer tokens de autenticación o explotar fallos de implementación para asumir temporal o permanentemente la identidad de otros usuarios. Comprometer la capacidad de un sistema para identificar al cliente/usuario compromete la seguridad de la API en general.
API3:2023 - Autorización de nivel de propiedad de objeto rota	Esta categoría combina API3:2019 Exposición Excesiva de Datos y API6:2019 - Asignación Masiva, centrándose en la causa raíz: la falta o una validación incorrecta de autorización a nivel de propiedad del objeto. Esto conduce a la exposición o manipulación de información por parte de partes no autorizadas.
API4:2023 - Consumo de Recursos Sin Restricciones	Satisfacer las solicitudes de API requiere recursos como ancho de banda de red, CPU, memoria y almacenamiento. Otros recursos como correos electrónicos, SMS, llamadas telefónicas o validación biométrica están disponibles por los proveedores de servicios mediante integraciones API y se pagan por solicitud. Los ataques exitosos pueden llevar a la denegación de servicio o a un aumento de los costes operativos.
API5:2023 - Autorización de nivel de función rota	Las políticas complejas de control de acceso con diferentes jerarquías, grupos y roles, y una separación poco clara entre funciones administrativas y regulares, tienden a generar fallos en la autorización.

95% Mayor, nublado

18/05/2024 16:28



Casos reales por vulnerabilidad

Vulnerabilidad	Empresa o caso	Año	Cómo fue explotada
A01 Broken Access Control	First American Financial	2019	Documentos financieros quedaron accesibles sin autenticación mediante URLs predecibles.
A01 Broken Access Control	Facebook "View As"	2018	Fallas en la función "View As" permitieron robar tokens de acceso y tomar cuentas.
A02 Cryptographic Failures	Adobe	2013	Se expusieron cuentas con contraseñas cifradas de forma débil y pistas de contraseñas en texto claro.
A02 Cryptographic Failures	LinkedIn	2012	Se filtraron hashes de contraseñas protegidos con SHA-1 sin salting adecuado.
A03 Injection	Equifax	2017	Se explotó una vulnerabilidad en Apache Struts, permitiendo acceso a información personal de millones de personas.
A03 Injection	Heartland Payment Systems	2008	Un ataque de SQL Injection permitió comprometer datos de tarjetas bancarias.

A04 Insecure Design	Microsoft Power Apps	2021	APIs y portales quedaron expuestos por un diseño/configuración que permitía acceso público a datos.
A04 Insecure Design	Facebook "View As"	2018	La combinación de errores en funciones del sistema permitió generar tokens de acceso no autorizados.
A05 Security Misconfiguration	Capital One	2019	Una mala configuración en un WAF permitió acceso no autorizado a datos en la nube.
A05 Security Misconfiguration	MongoDB expuestos	2017	Servidores MongoDB sin autenticación quedaron accesibles públicamente y fueron manipulados.
A06 Vulnerable and Outdated Components	Apache Struts / Equifax	2017	No se aplicó un parche disponible para Apache Struts, lo que permitió explotación remota.
A06 Vulnerable and Outdated Components	Log4Shell	2021	Versiones vulnerables de Log4j permitían ejecución remota de código.
A07 Authentication Failures	Facebook	2018	Tokens de sesión robados permitieron acceder a cuentas de usuarios.
A07 Authentication Failures	Uber	2016	Credenciales comprometidas permitieron acceso a recursos internos y datos sensibles.
A08 Software and Data Integrity Failures	SolarWinds Orion	2020	Actualizaciones del software Orion fueron comprometidas con malware en una cadena de suministro.
A08 Software and Data Integrity Failures	Codecov	2021	Un script Bash Uploader fue modificado sin autorización para extraer información sensible.
A09 Logging and Monitoring Failures	Target	2013	Alertas de seguridad no fueron atendidas a tiempo antes del robo de datos de tarjetas.
A09 Logging and Monitoring Failures	SolarWinds	2020	La actividad maliciosa permaneció sin detectarse durante meses.

A10 SSRF	Capital One	2019	Se usó una técnica SSRF para acceder a metadatos internos de AWS y obtener credenciales temporales.
A10 SSRF	Microsoft Exchange ProxyLogon	2021	Se explotó una falla de tipo SSRF para interactuar con servicios internos del servidor Exchange.

Código vulnerable vs código seguro

- **Ejemplo 1: A03 Injection**

Código vulnerable

```
const email = req.body.email;
const password = req.body.password;
const consulta = "SELECT * FROM usuarios WHERE email = '" + email +
'" AND password = '" + password + "'";
db.query(consulta);
```

Código seguro

```
const email = req.body.email;
const password = req.body.password;
const consulta = "SELECT * FROM usuarios WHERE email = ? AND password = ?";
db.query(consulta, [email, password]);
```

- **Ejemplo 2: A01 Broken Access Control**

Código vulnerable

```
app.get("/usuario/:id", (req, res) => {
  const usuario = obtenerUsuario(req.params.id);
  res.json(usuario);});
```

Código seguro

```
app.get("/usuario/:id", (req, res) => {
  if (req.user.id !== req.params.id && req.user.rol !== "admin") {
    return res.status(403).json({ mensaje: "Acceso denegado" }); }
  const usuario = obtenerUsuario(req.params.id);
  res.json(usuario);});
```

- **Ejemplo 3: A02 Cryptographic Failures**

Código vulnerable

```
const password = req.body.password;  
guardarPasswordEnBD(password);
```

Código seguro

```
const bcrypt = require("bcrypt");  
const password = req.body.password;  
const hash = await bcrypt.hash(password, 10);  
guardarPasswordEnBD(hash);
```

Vulnerabilidades

1. A03 Injection

Permitir que cualquier atacante pueda acceder directamente a la base de datos, puede causar robo de información, modificación o eliminación de información sensible.

2. A01 Broken Access Control

Es muy peligrosa porque permite que usuarios sin permisos accedan a la información y puede afectar tanto a clientes como a administradores.

3. A07 Identification and Authentication Failures

Si el sistema de autenticación falla cualquier persona puede acceder a la información y puedes hacer mal uso

4. A06 Vulnerable and Outdated Components

Muchas aplicaciones dependen de librerías externas. Si no se actualizan, una vulnerabilidad puede estar en ello

5. A10 Server-Side Request Forgery

puede permitir acceso a servicios internos que no están disponibles desde internet. Puede exponer credenciales o información interna.

Conclusión

En mi opinión personal, conocer las vulnerabilidades del OWASP Top 10 fue una experiencia muy rara. Al principio lo veía solo como un tema de investigación, pero conforme fui investigando me quedé sorprendida al descubrir que aplicaciones súper conocidas y de uso diario han pasado por este tipo de fallos de seguridad. Eso me hizo dudar y entender que ningún sitio es tan seguro como aparenta ser, y que todos, sin importar su popularidad, están expuestos a riesgos.

Esta investigación me deja claro que en futuros proyectos debo ser **mucho más cuidadosa con la seguridad**, no solo como un requisito de actividad, sino como una prioridad desde el inicio del desarrollo. En mi top 5 personal, elegí las

vulnerabilidades que me parecieron más interesantes y, a la vez, más sorprendentes. Conocer cada una de ellas fue impactante porque me mostró lo fácil que puede ser para un atacante una mala configuración, una entrada de datos sin validar o un control de acceso mal implementado.

Al final, considero que el OWASP Top 10 no solo es una guía técnica, sino una herramienta de precaución para cualquier persona que desarrolle o gestione aplicaciones. Aprendí que la seguridad no es un extra, sino una responsabilidad constante además de eso, es importante recalcar que con esta investigación me doy cuenta que nada es seguro y que por más conocida que sea la página o aplicación nuestra información no es segura

Referencias

- Krebs, B. (2019, 24 mayo). *First American Financial Corp leaked hundreds of millions of title insurance records*. Krebs on Security. <https://krebsonsecurity.com/2019/05/first-american-financial-corp-leaked-hundreds-of-millions-of-title-insurance-records/>
- Associated Press. (2018, 28 septiembre). *Facebook says security breach affected nearly 50 million accounts*. AP News. <https://apnews.com/>
- Have I Been Pwned. (2013). *Adobe*. <https://haveibeenpwned.com/breach/Adobe>
- Perez, S. (2016, 18 mayo). *117 million LinkedIn emails and passwords from a 2012 hack just got posted online*. TechCrunch. <https://techcrunch.com/2016/05/18/117-million-linkedin-emails-and-passwords-from-a-2012-hack-just-got-posted-online/>
- Cybersecurity and Infrastructure Security Agency. (2020). *Advanced persistent threat compromise of government agencies, critical infrastructure, and private sector organizations*. CISA. <https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-352a>
- SolarWinds. (2021). *An investigative update of the cyberattack*. <https://www.solarwinds.com/blog/an-investigative-update-of-the-cyberattack>
- Codecov. (2021). *Security incident postmortem*. <https://about.codecov.io/apr-2021-post-mortem/>
- CBS News. (2014, 5 febrero). *Target ignored data breach warnings, report says*. CBS News. <https://www.cbsnews.com/news/target-ignored-systems-hacking-warnings-report-says/>

- Capital One. (2019). *Facts about the Capital One cyber incident*. <https://www.capitalone.com/digital/facts2019/>
- OWASP Foundation. (2021). *OWASP Top 10: The ten most critical web application security risks*. <https://owasp.org/Top10/>